AWS MLA-C02 • DOMAIN 4 • PART 3

Securing ML and AI Workloads and Model Endpoints

Operating, Monitoring, and Securing ML and AI Solutions

03

THEORY-ONLY LEARNING SERIES

Monitor • Optimize • Secure



Least privilege starts with IAM

Every person and every job gets only the access it needs.

Identity policies

Control what users and roles can do.

- Scope actions tightly
- Avoid wildcard resources
- Separate dev and prod

Execution roles

Roles that SageMaker AI jobs and endpoints assume.

- Read training data in S3
- Pull images from ECR
- One role per workload

Resource controls

Policies attached to resources and accounts.

- S3 bucket policies
- KMS key policies
- SCPs and condition keys



Protect data, models, and artifacts

Fine-grained access plus encryption everywhere.

Data access

Limit who can read each dataset.

- S3 prefixes per team
- Lake Formation for tables
- Block public access

Model access

Control who can register, approve, and deploy.

- Model Registry permissions
- Tag-based access (ABAC)
- Approvers separate from builders

Encryption

Encrypt at rest and in transit.

- AWS KMS keys
- TLS for all traffic
- Inter-container encryption



Secure the CI/CD pipeline

Vulnerabilities are cheapest to fix before deployment.

Code scanning

Scan source code on every commit.

- Amazon Inspector code scans
- Find unsafe dependencies
- Fail builds on critical issues

Image scanning

Scan container images in Amazon ECR.

- Basic scanning on push
- Enhanced with Inspector
- Rescan as new CVEs appear

Secrets

Never hardcode credentials in code or buildspecs.

- AWS Secrets Manager
- Parameter Store
- Automatic rotation



Isolate the network and audit everything

Control where traffic goes and keep a record of every action.

Network isolation

- Private subnets and security groups
- VPC endpoints for SageMaker and Bedrock
- Network isolation mode for containers
- No public internet path to data

Audit and compliance

- CloudTrail records every API call
- AWS Config checks resource settings
- Trusted Advisor flags risky setups
- Logs kept in a separate account



Authenticate to foundation models securely

Prefer short-lived credentials over long-lived keys.

IAM credentials

Roles provide temporary credentials automatically.

- Best default choice
- No keys to store
- Fine-grained model access

Bedrock API keys

Simple keys for calling the Bedrock API.

- Short-term or long-term
- Handy for development
- Rotate and limit scope

AWS Secrets Manager

Store keys for external model providers.

- Encrypted with KMS
- Automatic rotation
- Retrieved at run time



Generative AI brings new security risks

The model itself can become an attack surface.

Prompt injection

Input that tries to override the system instructions.

- Direct user attacks
- Hidden text in documents
- Separate data from instructions

Data leakage

Sensitive information appearing in outputs.

- PII in responses
- Exposed system prompts
- Filter outputs

Excessive agency

Agents with more power than they need.

- Least-privilege tool roles
- Confirm risky actions
- Limit available tools



Amazon Bedrock Guardrails enforce safe outputs

One guardrail can protect many models and applications.

Content filters

Block harmful categories at set strengths.

- Hate, insults, violence
- Misconduct
- Prompt attack filter

Denied topics

Keep the app on topic and on brand.

- Define topics to refuse
- Custom word filters
- Profanity filter

Sensitive info

Detect PII and either block or mask it.

- Names, emails, SSNs
- Mask or block
- Custom regex patterns

Grounding checks

Flag answers not supported by the source.

- Grounding threshold
- Relevance threshold
- Reduces hallucinations



Troubleshoot access and network issues

Work through the layers in order instead of guessing.

1 — Read

Note the principal, action, and resource in the error

›

2 — Trace

Find the AccessDenied event in CloudTrail

›

3 — Policies

Check identity, resource, SCP, and KMS key policies

›

4 — Network

Check security groups, routes, and VPC endpoints

›

5 — Verify

Test with the IAM policy simulator, then retry

A permission can be allowed in one policy and denied in another. An explicit deny always wins.



A security checklist

Security is layered: identity, data, network, and model.

1. Give every user, job, and tool least-privilege access.
2. Encrypt data and models with AWS KMS and TLS.
3. Scan code and container images in the pipeline.
4. Use private networking and audit with CloudTrail and Config.
5. Prefer IAM roles and store other keys in Secrets Manager.
6. Defend against prompt injection with Bedrock Guardrails.

